Mobile Demo Script Explanation -- Pincode (Reversing, Challenge 02)

Olawoyin Joseph Pamilerin, ISU520196

In one sentence: The PIN check runs entirely on-device with no rate limiting -- all 1,000,000 combinations can be brute-forced offline.

Background -- what the terms below mean

What does "Reversing" mean, as a category? A **Reversing** challenge gives you someone else's already-built app (an APK) and asks you to figure out, by reading its code, some secret value it's hiding -- a PIN, a password, a flag string.

What is an APK, and what does "decompile" mean? An APK is the installable file for an Android app. It ships as compiled code that isn't directly readable, so we **decompile** it -- turn it back into readable, Java-like source code -- using a free tool called **jadx** (opened as **jadx-gui**).

Why is there no exploit app to build here? Reversing challenges usually aren't solved by writing an Android app at all -- they're solved by reading the decompiled logic and then writing a small script (usually Python) that re-implements or defeats that same logic on a regular computer, offline.

How the APK was obtained

The target APK was **downloaded directly from the challenge's own page** on challs.reyammer.io, before doing anything else. A copy of it is kept at:

```
C:\Users\Admin\Desktop\MOBISEC Challenge\Challenges\Reversing/02 Pincode\Original Target APK.apk
```

How the solution was built

No Android app was built for this one at all. It was solved by **decompiling the target with jadx** and then writing a small **Python script** (or, in a couple of cases, working the logic out by hand) that re-implements or defeats the exact same check on a regular computer, offline. The recovered value was then typed directly into the challenge's own flag box.

The vulnerability / technique, in plain terms

Brute-forced all 1,000,000 six-digit PINs against 10,000 rounds of MD5 each, using 4-core multiprocessing (~1h50m runtime), then submitted the recovered PIN to the server.

Files to open

1. Open the target APK in jadx-gui:

```
C:\Users\Admin\Desktop\MOBISEC Challenge\Challenges\Reversing/02 Pincode\Original Target APK.apk
```

2. PinChecker.java (jadx decompiled):

```
C:\Users\Admin\Desktop\MOBISEC Challenge\Challenges\Reversing/02 Pincode\Analysis and Scripts\Challenge 14 P
```

In jadx-gui's left tree: Source code -> com -> mobisec -> pincode -> PinChecker.java

3. brute.py:

C:\Users\Admin\Desktop\MOBISEC Challenge\Challenges\Reversing/02 Pincode\Analysis and Scripts\Challenge 14 P

What to say -- explanation of the exploit, step by step

1. I decompiled the APK and found the PIN check runs entirely on-device, hashing the candidate PIN through 10,000 rounds of MD5 with no rate limiting.

2. I wrote a brute-force script using 4-core multiprocessing to try all 1,000,000 six-digit PINs against the target digest (about 1h50m runtime).

3. Once the correct PIN was found, I typed it into the flag box to get the flag.

If an emulator isn't available

If asked how you got/confirmed the flag: "I decompiled the target with jadx, recovered the secret value with a script (no exploit app was built or uploaded for this one), and typed the recovered flag directly into the challenge site's own flag box." There is no APK submission or platform analysis log for this challenge -- don't claim one.

Result

The flag this challenge produced:

MOBISEC{local_checks_can_be_very_bad_for_security} (PIN 703958)

Source: Typed into the CTFd flag box; solve confirmed live from /user